Taller Aplicado Para Ciberseguridad

Docente: Cristian Navarrete O.

TAPC

Gobierno, gestión de riesgos y cumplimiento

En resumen, Gobierno, Gestión de Riesgos y Cumplimiento (GRC, por sus siglas en inglés) es un enfoque estratégico que integra la dirección, la gestión de riesgos y el cumplimiento normativo dentro de una organización para asegurar que se alcancen los objetivos de negocio de manera confiable, se gestionen los riesgos de forma efectiva y se cumplan todas las regulaciones aplicables

AIEP DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Gobierno, gestión de riesgos y cumplimiento

Gobierno: Se refiere a las estructuras, procesos y políticas que definen la forma en que una organización es dirigida y controlada. Esto incluye la definición de roles y responsabilidades, la toma de decisiones estratégicas y la implementación de políticas de gobernanza corporativa.

Gestión de Riesgos: Implica la identificación, evaluación, mitigación y seguimiento de los riesgos que pueden afectar a la organización. Esto incluye riesgos operativos, financieros, legales y reputacionales. La gestión de riesgos ayuda a tomar decisiones informadas y a proteger a la organización contra eventos adversos.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Gobierno, gestión de riesgos y cumplimiento

Cumplimiento: Se refiere a la adhesión a todas las leyes, regulaciones, normas internas y externas aplicables a la organización. El cumplimiento implica la implementación de controles y mecanismos de supervisión para asegurar que se cumplen todos los requisitos legales y éticos.

Importancia del GRC:

Alineación con los objetivos de negocio**:** El GRC asegura que todas las actividades de la organización estén alineadas con sus objetivos estratégicos.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Gobierno, gestión de riesgos y cumplimiento

Importancia del GRC:

Mayor eficiencia y productividad: Al integrar los procesos de gobierno, riesgo y cumplimiento, se reducen las redundancias y se optimizan los recursos.

Reducción de costos: Una gestión efectiva de riesgos y cumplimiento puede evitar multas, sanciones y pérdidas financieras.

Mejora de la reputación: Al operar de manera ética y transparente, la organización fortalece su reputación y genera confianza entre sus stakeholders.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Gobierno, gestión de riesgos y cumplimiento

Importancia del GRC:

Mayor resiliencia: La gestión de riesgos ayuda a la organización a prepararse y responder a eventos inesperados, aumentando su capacidad de recuperación.

En resumen, GRC es un enfoque integral que ayuda a las organizaciones a operar de manera más eficiente, segura y responsable.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Conceptos Generales dentro de un Empresa

Comité de dirección: Un comité de dirección, también conocido como CODIR o comité directivo, es un grupo de altos ejecutivos de una empresa que se reúne para definir la estrategia general, tomar decisiones clave y supervisar el rendimiento de la organización. Su objetivo principal es asegurar que la empresa opere de manera eficiente y alcance sus metas a largo plazo.

Funciones principales del comité de dirección:

Definir la estrategia: Establecer la dirección general de la empresa, incluyendo objetivos a largo plazo y estrategias para alcanzarlos.

Tomar decisiones: Analizar y decidir sobre asuntos importantes como inversiones, proyectos clave y cambios organizativos.

Supervisar el rendimiento: Monitorear el progreso de la empresa, evaluar el cumplimiento de los objetivos y tomar medidas correctivas si es necesario.

Coordinar áreas: Facilitar la comunicación y la coordinación entre los diferentes departamentos y áreas de la empresa.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Conceptos Generales dentro de un Empresa

Importancia del comité de dirección:

Visión estratégica: Permite a la alta dirección tener una perspectiva global de la empresa y tomar decisiones informadas.

Mayor eficiencia: Al coordinar los esfuerzos de diferentes áreas, se optimiza la eficiencia operativa y se evitan conflictos.

Mejor toma de decisiones: Al reunir diversas perspectivas y experiencias, se facilita la toma de decisiones más acertadas

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Gerente de seguridad de la información

Un Gerente de Seguridad de la Información, también conocido como CISO (Chief Information Security Officer) o Director de Seguridad de la Información, es responsable de la seguridad de la información de una organización. Su función principal es desarrollar, implementar y mantener políticas, procedimientos y controles para proteger los activos de información de la empresa contra amenazas internas y externas

TAPC

Gerente de seguridad de la información

Responsabilidades clave de un Gerente de Seguridad de la Información:

Desarrollo e implementación de políticas y procedimientos de seguridad: Creación de un marco de seguridad robusto para proteger la información, sistemas y redes de la organización.

Gestión de riesgos: Identificación y evaluación de riesgos de seguridad, desarrollo e implementación de estrategias para mitigarlos.

Gestión de incidentes de seguridad: Preparación y respuesta a incidentes de seguridad, minimizando el impacto en la organización.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Gerente de seguridad de la información

Requisitos para ser Gerente de Seguridad de la Información:

Experiencia: Amplia experiencia en seguridad informática, generalmente 10 años o más, con experiencia en roles de liderazgo.

Conocimientos técnicos: Sólidos conocimientos en seguridad de sistemas, redes, aplicaciones, y en la legislación aplicable.

Habilidades de liderazgo y gestión: Habilidades para liderar equipos, tomar decisiones y resolver problemas.

Formación académica: Generalmente se requiere un título universitario en informática, seguridad de la información o un campo relacionado.

Certificaciones: Certificaciones como CISSP, CISM o similares son altamente valoradas.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Profesionales de la ciberseguridad

Un experto en ciberseguridad es un profesional que se dedica a proteger sistemas informáticos, redes y datos contra ataques, daños o accesos no autorizados. Su principal objetivo es garantizar la integridad, confidencialidad y disponibilidad de la información y recursos tecnológicos.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Profesionales de la ciberseguridad

Funciones principales de un experto en ciberseguridad

Diseñar estrategias y acciones: Desarrollan e implementan medidas para proteger los entornos digitales de las empresas o instituciones.

Analizar amenazas: Monitorean y analizan las amenazas de seguridad, investigan incidentes y desarrollan medidas preventivas.

Implementar medidas de seguridad: Diseñan e implementan sistemas de seguridad como firewalls, sistemas de detección de intrusiones, y sistemas de gestión de identidad y acceso.

Educar sobre seguridad: Informan y capacitan a los usuarios sobre buenas prácticas de seguridad para prevenir errores humanos que puedan generar vulnerabilidades

Responder a incidentes: Actúan rápidamente ante incidentes de seguridad, investigando, conteniendo y recuperando sistemas afectados.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Profesionales de la ciberseguridad

- Habilidades y conocimientos esenciales:
- Amplios conocimientos en seguridad informática y redes
- Habilidades en análisis de amenazas, detección de vulnerabilidades y respuesta a incidentes.
- Capacidad para diseñar e implementar soluciones de seguridad
- Habilidades de comunicación para educar y concientizar sobre seguridad
- Capacidad de trabajo en equipo y bajo presión

AIEP DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Dominios de la ciberseguridad

Los dominios de la ciberseguridad son las diferentes áreas especializadas dentro del campo de la seguridad informática, cada una con su propio conjunto de habilidades y enfoques. Algunos de los dominios más importantes incluyen la seguridad de la red, la seguridad de aplicaciones, la seguridad en la nube, la gestión de identidad y acceso (IAM), la seguridad de datos, la respuesta a incidentes y la gestión de riesgos y cumplimiento (GRC).

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Dominios de la ciberseguridad

Aquí hay una descripción más detallada de algunos de estos dominios:

Seguridad de la red: Se enfoca en proteger la infraestructura de red, incluyendo firewalls, sistemas de detección de intrusiones y sistemas de prevención de intrusiones

Seguridad de aplicaciones: Se centra en asegurar las aplicaciones de software, tanto en desarrollo como en producción, incluyendo el análisis de código, la gestión de vulnerabilidades y la seguridad en el ciclo de vida del desarrollo de software

Seguridad en la nube: Aborda la seguridad de los servicios y la infraestructura en la nube, como Amazon Web Services (AWS), Microsoft Azure y Google Cloud Platform (GCP)

Gestión de identidad y acceso (IAM): Se ocupa de la gestión de identidades digitales y el control de acceso a los recursos, asegurando que solo las personas autorizadas tengan acceso a la información y sistemas necesarios

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Dominios de la ciberseguridad

Aquí hay una descripción más detallada de algunos de estos dominios:

Seguridad de datos: Se centra en proteger la confidencialidad, integridad y disponibilidad de la información, incluyendo la gestión de datos sensibles, el cifrado y las políticas de retención de datos

Respuesta a incidentes: Se ocupa de la gestión de incidentes de seguridad, incluyendo la detección, contención, erradicación y recuperación de ataques

Gestión de riesgos y cumplimiento (GRC): Se enfoca en la identificación, evaluación y gestión de riesgos de seguridad, así como en el cumplimiento de leyes y regulaciones relacionadas con la seguridad de la información

Además de estos dominios, existen otros como la seguridad física, la seguridad de los endpoints, la inteligencia de amenazas y la seguridad en el Internet de las cosas (IoT). La ciberseguridad es un campo vasto y en constante evolución, y cada dominio juega un papel crucial en la protección de los activos digitales de una organización

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Principios de arquitectura de seguridad

Los principios de arquitectura de seguridad son las pautas y conceptos fundamentales que guían el diseño e implementación de sistemas seguros. Estos principios aseguran que los sistemas sean resistentes a ataques y protejan la información confidencial. Algunos de los principios clave incluyen la defensa en profundidad, el mínimo privilegio, la separación de funciones, la seguridad por diseño y la simplicidad.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Principios de arquitectura de seguridad

Principios clave de arquitectura de seguridad

Defensa en profundidad: Implica la implementación de múltiples capas de seguridad para proteger el sistema. Si una capa falla, otras capas siguen ofreciendo protección.

Mínimo privilegio: Los usuarios y sistemas solo deben tener acceso a los recursos y permisos necesarios para realizar sus tareas. Esto reduce el impacto de posibles compromisos.

Separación de funciones: La responsabilidad de ciertas tareas se divide entre diferentes personas o sistemas para evitar que un solo punto de fallo pueda comprometer la seguridad.

Seguridad por diseño: La seguridad se considera desde las etapas iniciales del desarrollo del sistema, en lugar de agregarse como una solución posterior.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Principios de arquitectura de seguridad

Principios clave de arquitectura de seguridad

Simplicidad: Un sistema más simple es más fácil de entender y asegurar, reduciendo la probabilidad de errores de configuración y vulnerabilidades. Se conoce también como principio KISS (Keep It Simple, Stupid).

Confidencialidad, Integridad y Disponibilidad (CIA): Estos tres principios fundamentales aseguran que la información sea accesible solo para usuarios autorizados, que la información no sea alterada de forma no autorizada y que la información esté disponible cuando se necesita.

Confianza cero (Zero Trust): Un modelo de seguridad que no confía en ningún usuario o dispositivo, incluso si están dentro de la red corporativa. Requiere verificación constante para cada solicitud.

Responsabilidad compartida: En entornos de nube, la seguridad es una responsabilidad compartida entre el proveedor de la nube y el cliente.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Principios de arquitectura de seguridad

Al aplicar estos principios, las organizaciones pueden construir sistemas más seguros, reducir el riesgo de ataques cibernéticos y proteger mejor su información valiosa. Además, estos principios ayudan a cumplir con las regulaciones y normativas de seguridad.

TAPC

Seguridad de redes, sistemas, aplicaciones y datos

La seguridad de redes, sistemas, aplicaciones y datos es un conjunto de prácticas y tecnologías diseñadas para proteger la información y los recursos digitales de accesos no autorizados, amenazas cibernéticas y pérdida de datos. Esto abarca la protección de la infraestructura de red, los sistemas operativos, las aplicaciones y la información almacenada y en tránsito.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Seguridad de redes, sistemas, aplicaciones y datos

Seguridad de Redes

Protección de la infraestructura: Se enfoca en la seguridad de la red física y virtual, utilizando firewalls, sistemas de detección de intrusiones y otras tecnologías para evitar accesos no autorizados y ataques como malware y DDoS.

Confidencialidad, Integridad y Disponibilidad (CIA): Principios fundamentales de la seguridad de redes, asegurando que la información sea accesible solo para usuarios autorizados, que no sea alterada de forma no autorizada y que esté disponible cuando sea necesaria.

Protección del tráfico: Incluye medidas para proteger el tráfico de datos que viaja a través de la red, como el cifrado de datos en tránsito y la implementación de VPNs.

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Seguridad de redes, sistemas, aplicaciones y datos

Seguridad de Sistemas

Protección de sistemas operativos: Se centra en la seguridad de los sistemas operativos, asegurando que estén protegidos contra vulnerabilidades, malware y ataques que puedan comprometer su funcionamiento.

Gestión de parches y actualizaciones: Implica la aplicación regular de parches y actualizaciones para corregir vulnerabilidades y mantener los sistemas seguros.

Control de acceso: Establecer políticas y mecanismos para controlar quién puede acceder a los sistemas y qué acciones pueden realizar, utilizando contraseñas seguras, autenticación multifactor y control de acceso basado en roles (RBAC)

AIEP
DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Seguridad de redes, sistemas, aplicaciones y datos

Seguridad de Aplicaciones

Protección contra ataques a nivel de aplicación: Se enfoca en la seguridad del código de las aplicaciones, utilizando técnicas como la validación de entradas, la prevención de inyecciones de código SQL y la protección contra ataques de cross-site scripting (XSS).

Desarrollo seguro: Incluye prácticas de desarrollo seguro desde las primeras etapas del ciclo de vida de desarrollo de software, para evitar vulnerabilidades desde el diseño.

Seguridad en la nube: Abarca las medidas de seguridad específicas para aplicaciones y datos que se ejecutan en la nube, incluyendo el control de acceso, la protección de datos y la gestión de identidades.

AIEP DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Seguridad de redes, sistemas, aplicaciones y datos

Seguridad de Datos

Protección de datos en reposo y en tránsito: Implica el cifrado de datos, tanto cuando están almacenados como cuando se transmiten a través de redes, para protegerlos de accesos no autorizados y pérdidas de información.

Cumplimiento normativo: Asegurar que las políticas y prácticas de seguridad de datos cumplan con las leyes y regulaciones aplicables, como el RGPD (Reglamento General de Protección de Datos).

Copias de seguridad y recuperación ante desastres: Implementar copias de seguridad regulares y planes de recuperación ante desastres para asegurar la continuidad del negocio en caso de pérdida de datos o fallos del sistema

AIEP DE LA UNIVERSIDAD ANDRES BELLO

TAPC

Seguridad de redes, sistemas, aplicaciones y datos

La seguridad integral de redes, sistemas, aplicaciones y datos requiere un enfoque holístico que involucre políticas, procedimientos, tecnologías y capacitación del personal. Es fundamental una evaluación continua de riesgos y la implementación de medidas de seguridad adaptadas a las necesidades específicas de cada organización.

AIEP DE LA UNIVERSIDAD ANDRES BELLO